

T1 Evidence Check: Agent Identity

Each claim in the two editions, traced to the experiment and the recorded evidence behind it, with a status: supported, qualified, contradicted or not tested.

T1

T1 · Production AI Engineering

8 min read · Published 2026-10-03 · Evidence Check

01 · The question we tested

If the same privileged rollback is executed through different identity models, what identity, authority, attribution, revocation and replay properties survive? The POC runs one production rollback under three identity models and tries to break each one.

02 · What ran

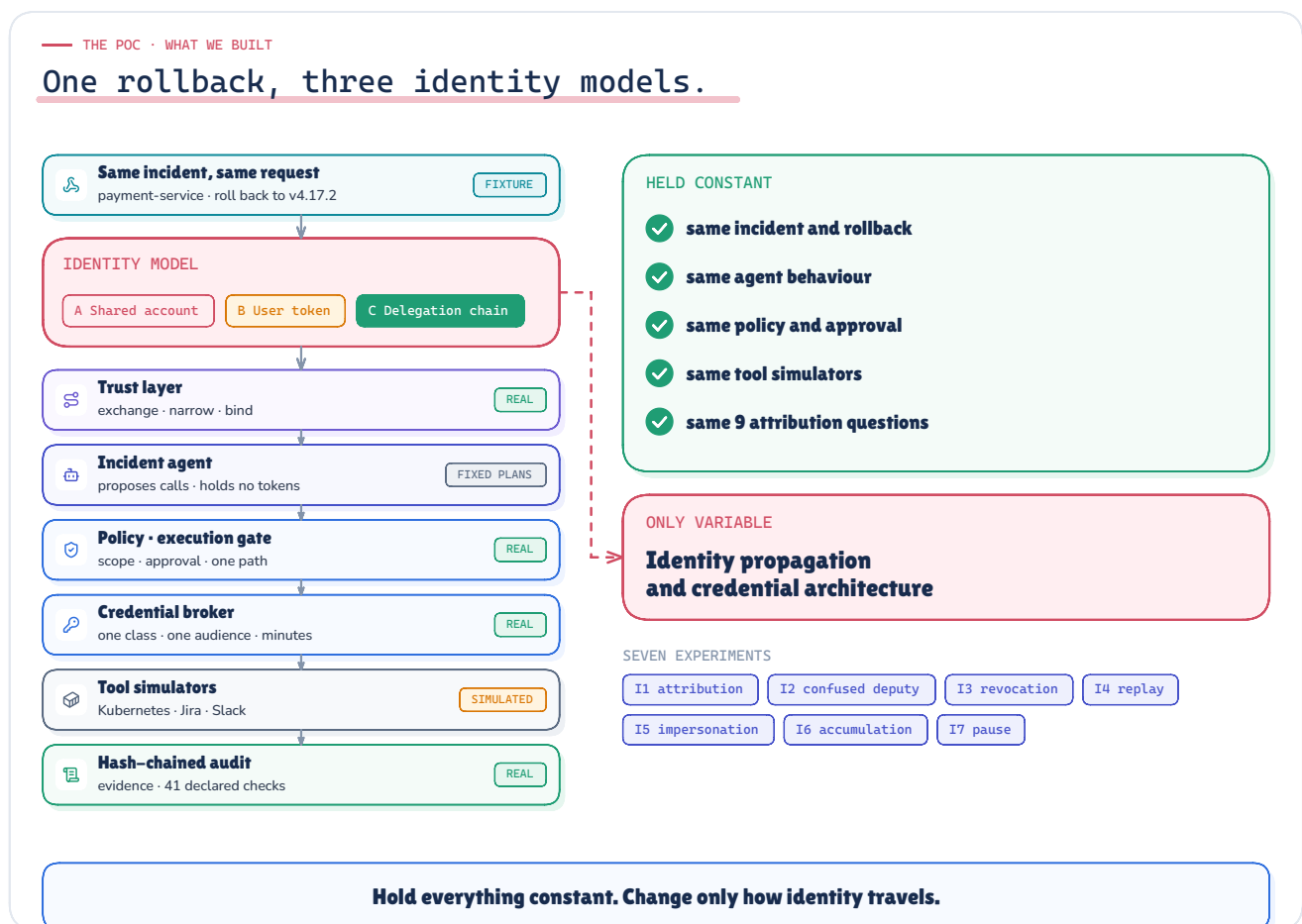


Figure 1. The testbed: one rollback, three identity models, everything else held constant.

Implemented: the POC's components and the held-constant fixture; experiment list from the run · run 2026-10-03-recorded

The identity code is real: token exchange, delegation and narrowing, attestation checks, the token broker, the capability gateway, approvals, the hash-chained audit and the revocation levers. The directory, workload attestation, Kubernetes, Jira, Slack, telemetry and the clock are simulated and deterministic, and the agents follow fixed plans. Real vs simulated itemises the split. Every observed value is in the Run Report, and every scenario, with its input, output, recorded steps and data lineage, is in the Lab Console.

03 · Method

Held constant. The incident (payment-service at 14% errors, Datadog event `dd-evt-771204`), the rollback, the agents' plans, the policy fixture, the approval fixture, the simulated tools and their logs, the run configuration, the scenarios and the nine attribution questions.

The only variable. Identity propagation and credential architecture. **A** one shared service account. **B** the user's token handed to the agent (impersonation). **C** a delegation chain: subject plus actor chain, intersected scopes, a workload-bound execution token, a broker minting one narrow credential per capability class, and a hash-chained audit record.

Declared criteria. 41 checks are declared in `agent_identity_poc/proof/preregistration.toml` : 30 experiment checks and 11 global assertions. Each has an id (`I2-01` , `G03`), a kind and an arm. They were frozen with `aid freeze` before the final recorded run, and the run refuses to start if a frozen file changed. Stated plainly: 29 of the experiment checks pre-date this pass, and their results were known from an earlier run. This pass kept them unchanged, added one I4 check (a privileged write replayed from the wrong workload) and the global assertions, and froze all of them first. One change followed the freeze, logged in `proof/DEVIATIONS.md` : the manifest's test count. It affects no check.

The nine attribution questions. For the rollback, can the record say: A1 which logical agent acted; A2 who or what invoked it; A3 on whose behalf; A4 with what delegated authority; A5 on which runtime; A6 which edge credential reached the tool; A7 what exact action on which resource; A8 who approved it; A9 whether each part can be revoked independently. A question counts only when the record states the true value. These are the POC's canonical definitions. The trigger and invoker fall under A2, policy and approval under A8, and the edge principal and action under A6 and A7. Agent version is not a separate question.

04 · Results at a glance



Figure 2. The POC in numbers. Every value is read from the recorded run.
Measured: I1–I7 headline results · run 2026-10-03-recorded

Experiment	Question	A · Shared account	B · User token	C · Delegation chain
I1 Attribution	Questions answered by the platform record (of 9)	3	4	9
I1 Attribution	Questions answered by Kubernetes' own log (of 9)	2	3	2
I2 Confused deputy	Rollbacks when a read-only agent asks	1	1	0 (DENY)
I3 Revocation	Executions stopped by one lever (of 5)	5	n/a	1 to 4
I4 Replay	Approved rollback replayed from another workload	n/a	n/a	REJECTED, 0 rollbacks
I5 Impersonation	Identity fields lost against the chain	n/a	13	0
I6 Accumulation (derived)	Permissions held	20	n/a	at most 3 per tool identity
I7 Pause	Revoked during a 37-minute wait	EXECUTED	n/a	REJECTED after re-exchange

41 of 41 declared checks passed; 0 failed.

05 • Claim → evidence

Status. **SUPPORTED:** the recorded run shows it and a declared check asserts it. **QUALIFIED:** the run shows it holds only within a stated bound. **CONTRADICTED:** a declared check failed. **NOT TESTED:** the POC was not built to show it. Paths are relative to `agent_identity_poc/runs/2026-10-03-recorded/`.

#	Claim	Experiment	Evidence path	Status	Notes
1	A shared service account destroys agent attribution.	I1	I1.json ; I1-04, I1-05	SUPPORTED	Platform record 3/9; 0 of 3 agents attributable; Kubernetes saw 1 principal
2	Handing the agent the user's token keeps the human visible but erases the agent and the actor chain.	I1, I5	I1.json , I5.json ; I5-01, I5-03, G08	SUPPORTED	4/9; 13 identity fields lost; the agent's rollback indistinguishable from Maya's own. A finding about this architecture, not a verdict on impersonation in general
3	A delegation chain keeps every actor attributable from the platform record.	I1, I5	I1.json , audit.jsonl , I5.json ; I1-02, I1-06, I5-02, G10	SUPPORTED	9/9; 3 of 3 agents attributable; the agent's action distinguishable from Maya's own
4	No tool log is complete upstream provenance, whatever the architecture.	I1	I1.json , tool-logs.json ; I1-03, G09	SUPPORTED	Kubernetes' log answered at most 3 of 9 in every model; it proves the edge principal acted
5	Agent identity and runtime identity stay distinct in the record.	I1	I1.json platform record; G07	SUPPORTED	The record names the agent and the attested workload separately
6	Delegation never widens authority; the confused deputy is denied before any approval.	I2	I2.json ; I2-01, I2-02, I2-03, G01, G02	SUPPORTED	Chain: DENY under rule P1-missing-scope, 0 rollbacks; the callee's scopes narrowed to deploy:read, itsm:read, telemetry:read
7	Approval cannot compensate for a missing identity.	I2	I2.json ; I2-04	SUPPORTED, in this scenario	Shared account and user token: the approver saw agent.incident-intel , approved, 1 rollback ran; the originator never appeared
8	Separate identities make revocation granular; a shared account can only stop everything.	I3	I3.json ; I3-01, I3-03 ... I3-07, G05, G06	SUPPORTED	Targeted levers stopped 1 to 4 of 5; rotating the shared account stopped 5; with no lever, nothing stopped
9	A revoked identity cannot mint new execution authority.	I3, I7	I3.json , I7.json ; I3-03, I7-01, G04	SUPPORTED	New starts after revoking the invoker credential: refused: unknown or revoked credential ; after the pause, re-exchange under the revoked delegation: REJECTED
10	A copied or expired execution token is useless away from its workload and its lifetime.	I4	I4.json , scenarios/I4-chain-other-workload-write/ ; I4-01, I4-02, I4-03, G03	SUPPORTED	An approved rollback replayed from another workload: REJECTED, 0 rollbacks; the legitimate call after it: EXECUTED. Rests on sender constraint (here a workload binding), not on bearer claims

#	Claim	Experiment	Evidence path	Status	Notes
11	A pause requires re-deriving authority, not extending it.	I7	I7.json ; I7-01, I7-02, G04	SUPPORTED	Re-exchange after revocation: REJECTED; extending the old token: EXECUTED (1 rollback)
12	Tampering with the platform record is detected at the edited row.	I1	I1.json ; I1-07, G11	SUPPORTED	Editing the approver in one of 8 rows broke verification at row 8
13	A stolen tool credential is harmless.	I4	I4.json ; I4-04, I4-05 (qualified), I4-06	QUALIFIED	Within its 10 minutes: 200; after: 401; at another audience: 401. The shared secret still returned 200 a day later
14	Revocation takes effect immediately.	I3	I3.json ; I3-02 (qualified)	QUALIFIED	Levers checked online at the gateway acted at the next call; the delegation and invoker-credential levers took up to 10 minutes, bounded by the 15-minute execution token. A credential's lifetime is its revocation deadline
15	The audit answers every attribution question.	I1	I1.json , tool-logs.json ; G09, G10	QUALIFIED	Complete only where the platform recorded it: the platform record answered 9/9, the tool's log at most 3
16	The hash-chained audit is non-repudiable evidence.	I1	I1.json ; I1-07, G11	QUALIFIED	Tamper-evident, not tamper-proof: an application hash chain is not an independently anchored ledger
17	A shared account accumulates privilege.	I6	I6.json ; I6-01	QUALIFIED	Derived from configuration, not measured at run time: 20 held, 6 needed, 14 excess
18	The pattern behaves the same with a commercial identity provider.	none	none	NOT TESTED	The directory and identity provider are simulated (config/principals.yaml)
19	Workload binding resists a real attacker.	none	none	NOT TESTED	Attestation and SVIDs are simulated; the binding check compares identities, it does not verify a cryptographic proof of possession
20	Resource servers understand actor and delegation claims.	none	none	NOT TESTED	No tool in the POC reads actor claims; the chain lives in the platform record
21	The broker and gateway add acceptable latency and stay available.	none	none	NOT TESTED	Not measured
22	The pattern holds against a model that tries to talk its way into more authority.	none	none	NOT TESTED	Agents follow fixed plans

Claim numbers are shared with the Technical edition (§36 supported, §37 qualified, §38 not tested). Every declared check is cited by at least one claim, except I1-01, the setup control that the rollback executed exactly once in every mode.

Contradicted: none. 0 of 41 declared checks failed. The global assertions G01–G11 all held (11 of 11).

06 · What the POC qualified

MEASURED

REASONED

from I3, I4 and I6; the bound is stated for each

Short-lived is not the same as instantly revocable. Two findings limit the pattern, and both are properties of self-contained credentials rather than bugs in the POC.

- **A stolen tool credential has a bounded window.** The broker's `incident-remediator` credential worked against Kubernetes for its remaining minutes (200 within 10 minutes, 401 after) and nowhere else (401 at Jira). Sender-constrained tool credentials (mTLS-bound ^[3] or DPoP ^[4]) would close the window; most tools don't accept them, which is why the lifetime is kept short.
- **Revocation latency is bounded by the token lifetime.** Revoking Maya's delegation stopped her executions at their next re-exchange, up to 10 minutes later, because the execution token already issued stays valid until it expires. Levers the gateway checks on every call (agent, workload, tool identity) acted at once. Token introspection, or a revocation list consulted per call, would remove the bound at the cost of an online dependency.

Two more bounds, stated plainly. The tool still sees only the edge: Kubernetes cannot reconstruct provenance it was never given. And the platform record is hash-chained application audit, tamper-evident but not an independently anchored ledger.

07 · What this evidence does not show

- **Real identity providers and attestation.** SVIDs, the directory and the tools' audit logs are simulated; RFC 8693 is implemented as data structures, not as wire format.
- **Resource servers that understand actor claims.** The simulated tools authenticate the edge credential only.
- **Performance and availability.** Nothing here measures a token broker's latency or availability in the request path.
- **Model behaviour.** Agents follow fixed plans. The claims are about who acts and with what authority, which must hold whatever a model proposes.
- **Policy depth.** Policy has only the rules identity needs; authorization is the next note.

- **One run.** The run is deterministic, so repetition adds no statistical weight; the evidence is the checks, not a distribution.

08 • Reproduce and verify

```
cd agent_identity_poc && uv sync --group dev
uv run pytest                                # including test_experiments.py: I1-I7
and G01-G11
uv run aid experiments --run-id 2026-10-03-recorded # refuses to run if a frozen file changed
cd .. && make verify                            # rerun into a fresh copy, diff byte for
byte
make console                                  # rebuild the Lab Console from the run
directories
```

09 • Sources

The numbers match the Technical edition's reference list.

[3] RFC 8705 — OAuth 2.0 Mutual-TLS Client Authentication and Certificate-Bound Access Tokens — IETF (Feb 2020) · STANDARD

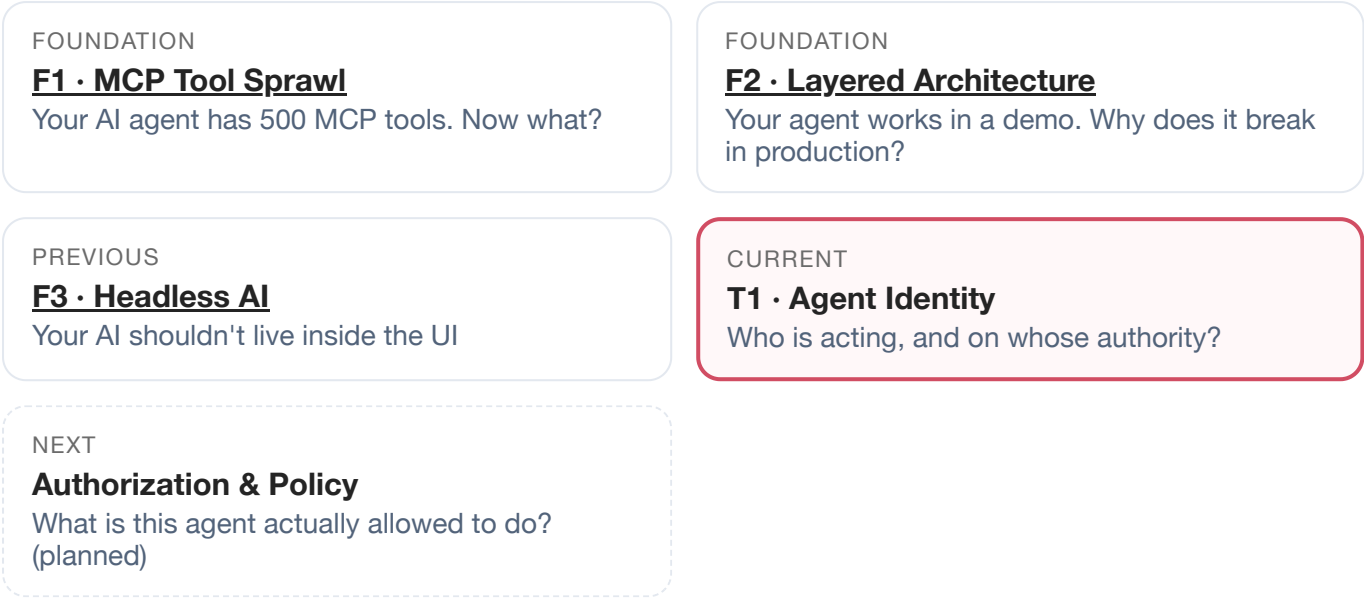
[4] RFC 9449 — OAuth 2.0 Demonstrating Proof of Possession (DPoP) — IETF (Sep 2023) · STANDARD

Evidence

Claims

Agent identity

PRODUCTION AI ENGINEERING · THE SERIES SO FAR



[The full learning map \(Start Here\)](#)

T1 · Production AI Engineering

Production AI Engineering · T1 · Evidence. Every measured number here is substituted at build time from `agent_identity_poc/runs/2026-10-03-recorded/facts.json`; the enterprise systems are simulated and the run is deterministic. Figures carry their provenance.

[Medium edition](#) [Technical deep dive](#) [POC README](#) [Run summary](#) [QA report](#)